

Level 7

Title: Command Injection & Hidden File Discovery

Analyst: Alex Mbogo

Target: Hack This Site

Approach:

- Observed hint indicating a password stored in a file within the same directory
- Identified a script executing the UNIX cal command based on user input
- Tested input handling for possible command injection
- Injected additional commands to list directory contents (e.g., ls)
- Discovered hidden/obscure file containing the password
- Retrieved password by accessing or reading the file

Finding:

- Web application vulnerable to command injection
- User input was not sanitized before being passed to a system command
- Sensitive file stored in accessible directory and discoverable via injection

Lesson:

- Never pass user input directly into system commands without sanitization
- Use safe APIs instead of shell execution
- Restrict file access and avoid storing sensitive data in web-accessible directories

Disclaimer: For educational purposes only



